

Unconventional Initial Access Vectors Pt. 2

 seccore.at/blog/iavpt2

Benjamin Floriani, Patrick Pongratz

December 9, 2025



We presented this topic at the DeepSec¹ and BSidesVienna² conferences. Both conferences were a great experience, and we enjoyed meeting old friends and making new ones! Big shoutout to all organizers and attendees for making these events such a great time!

What already happened

In the first part of our blog series³ about unconventional initial access vectors, we explained how we used SVG files with embedded JavaScript to drop a phishing page onto a target system. This phishing page was then used to send credentials to our backend, which in turn triggered an MFA challenge using an automated browser. Our first post focused mainly on the phishing vector and our backend, with some insights into how we built it and what is possible with it.

We also released a PoC script that can be used to generate SVG files with embedded JavaScript. You can find it on our GitHub page: <https://github.com/SecCoreGmbH/svgpoc>

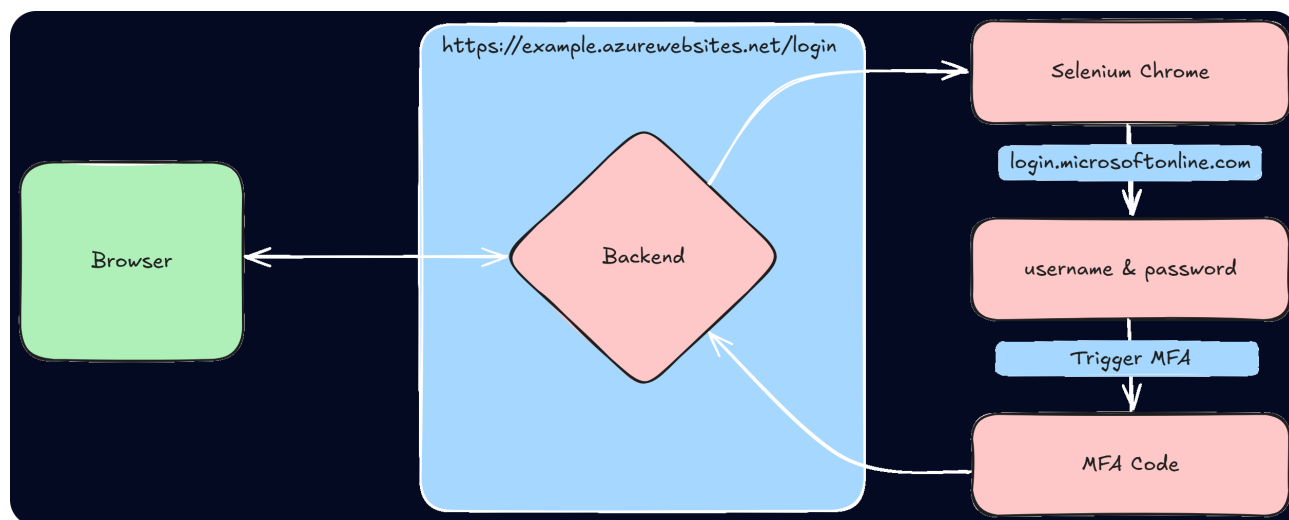
In this second part, we will elaborate on how we can bypass Conditional Access policies in Microsoft Entra-ID and what happens after initial access is established.

The Backend revisited

We already explained the general idea of our backend in the first part of this blog⁴. However, we did not yet explain how the architecture of our backend allows us to bypass common network security measures and access policies like Entra-ID Conditional Access. Therefore, we have compiled four possible scenarios that we can encounter during an engagement, and how our backend helps us to deal with them.

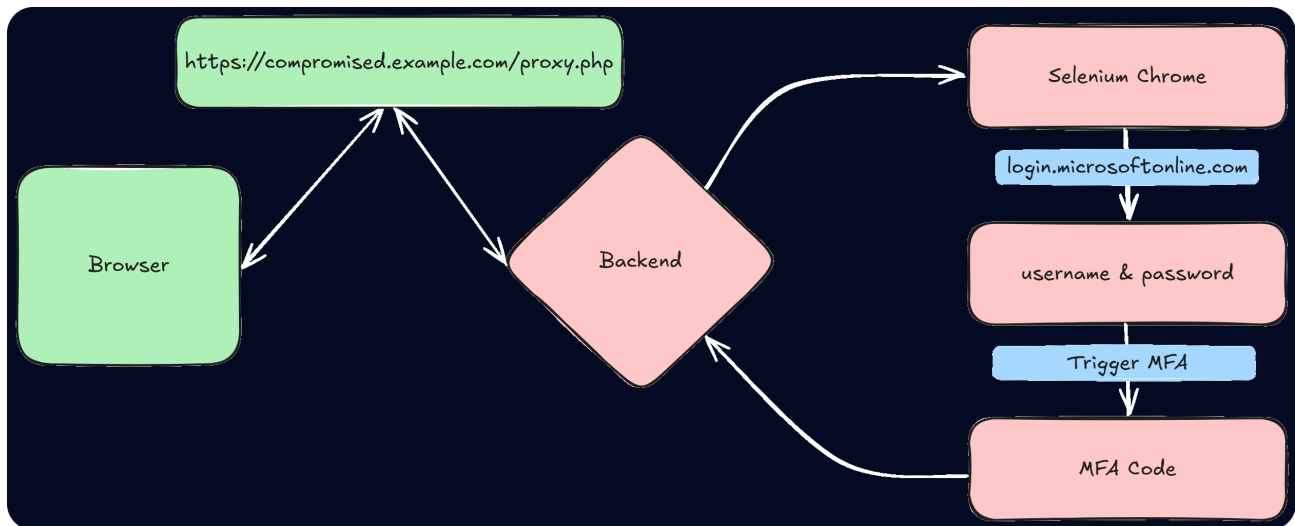
Scenario 1: DNS Block

One very common protection mechanism that we encounter is a DNS block of uncategorized domains. Making a domain look legit takes some work, so instead of going that route, we simply host our backend on a domain that is usually trusted. Such domains include cloud providers like AWS, Azure or Google Cloud, but also content delivery networks (CDNs). Since these domains are usually not blocked, our phishing page can reach our backend without any issues.



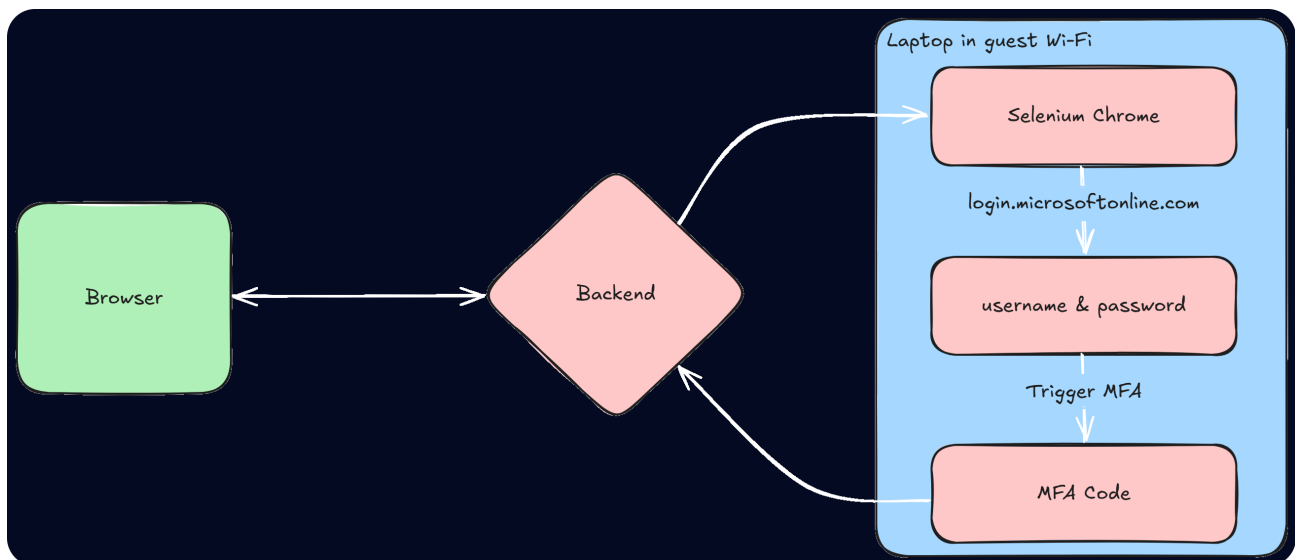
Scenario 2: DNS Allowlisting

In some cases, employees are only allowed to access a predefined list of trusted domains. These usually include business services like Microsoft 365 or Google Workspace. Also, company-owned websites and domains are typically allowed. Since the scope of a full Red Team Engagement⁵ also includes the external perimeter of a company, we can also compromise an externally facing system and host our backend there. This way, the phishing page can still reach our backend without being blocked.



Scenario 3: Conditional Access - Location-based

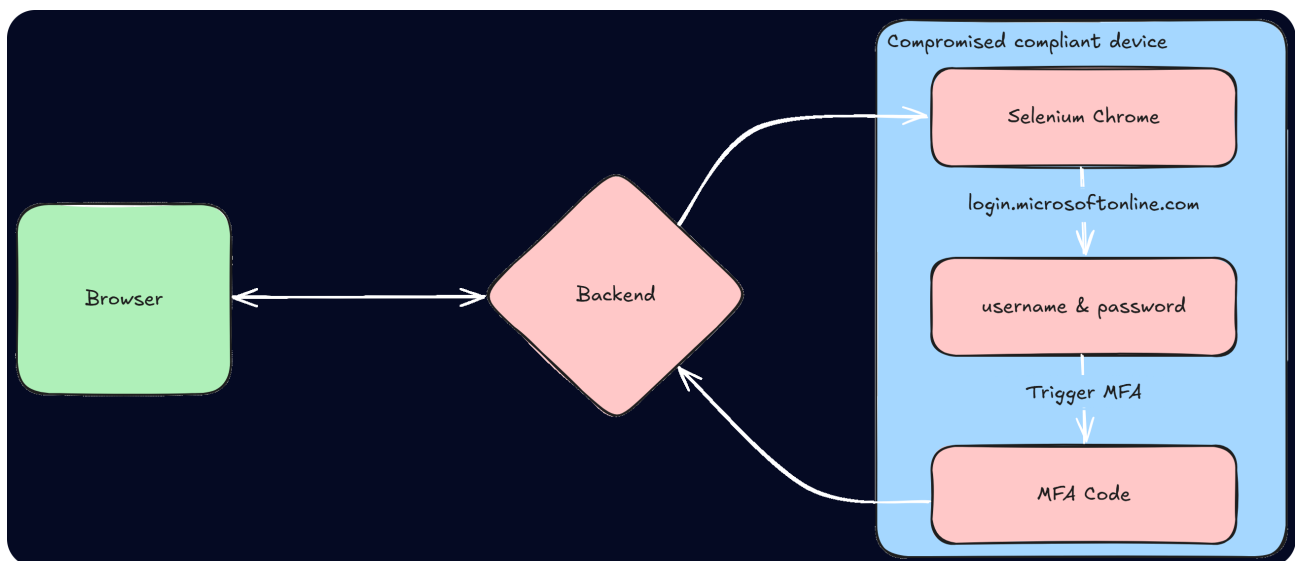
A Conditional Access policy that is based on the location of a user is a common way to restrict access to sensitive settings. For example, access to the admin portal of Entra-ID might only be allowed from within the corporate network or a specific country. We can bypass country-based restrictions by hosting our backend on a server that is geographically close to the target (just like in Scenario 1 or 2). For stricter policies, that only allow access from within a corporate network, we can run the automatic browser on a laptop that is connected to the guest network of our target. This way, the login attempt looks like it is coming from within the corporate network, and access is granted.



Scenario 4: Conditional Access - Device-based

Another (albeit theoretical) scenario is hosting the automated browser on a device that is marked as compliant in Entra-ID. This way, even strict Conditional Access policies that require a compliant device can be bypassed. This scenario however requires a lot of prior access. A laptop with working credentials would have to be compromised or stolen first, so

this scenario is intended to demonstrate what is possible rather than something that can easily be achieved.



Persistence

We will pick up the story from where we left it in the first part of our blog series: After the user approved the sign-in on their Microsoft Authenticator app, our automated browser is now fully authenticated and we have initial access to the target environment. Our backend extracts MS-Graph tokens and writes them to a file to be used with tools such as GraphRunner⁶:

```
(karl@hp-laserjet)-[/home/karl/GraphRunner]
PS> $tokens = Get-Content 'token.json' | Out-String | ConvertFrom-Json

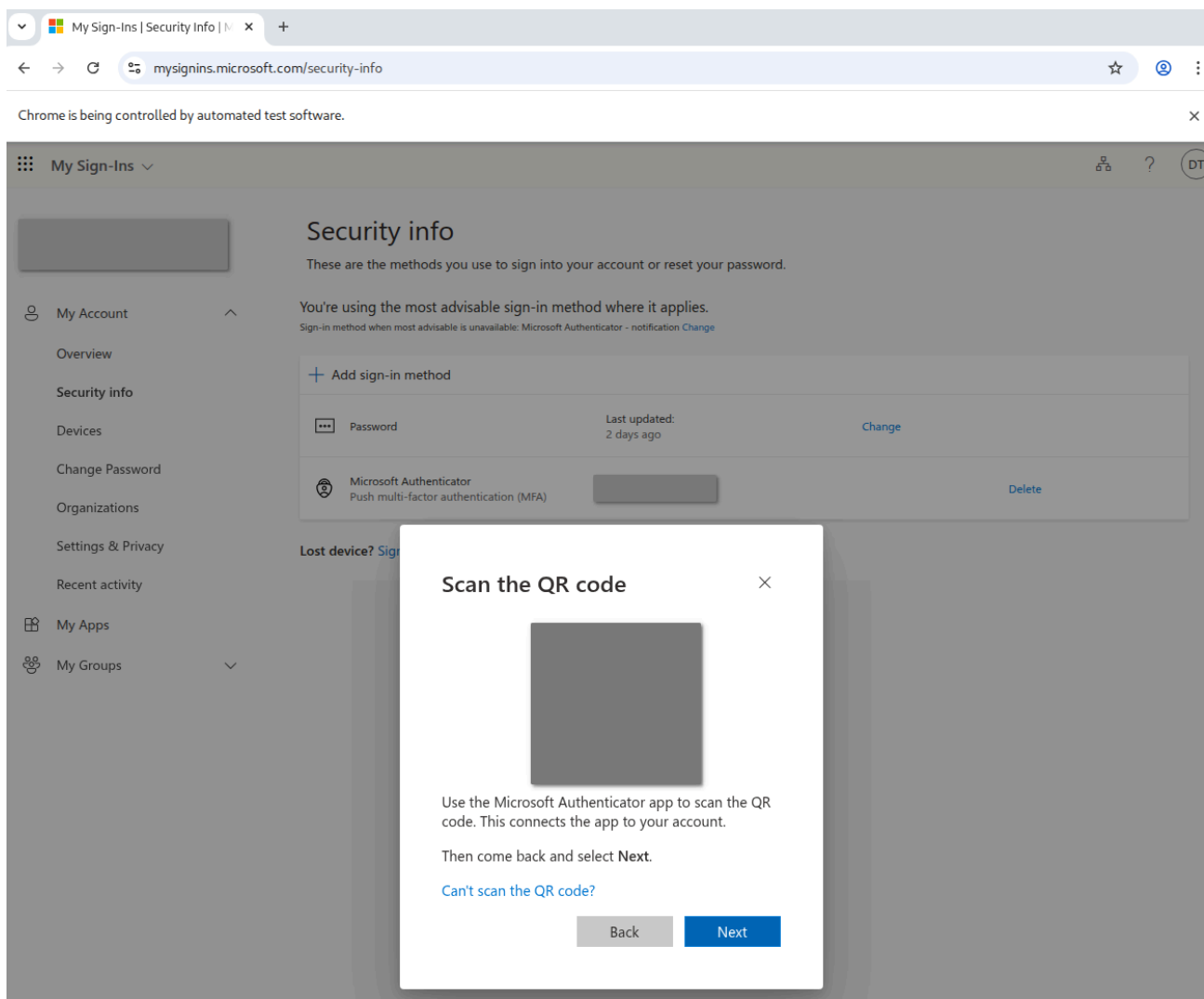
(karl@hp-laserjet)-[/home/karl/GraphRunner]
PS> Get-AzureADUsers -Tokens $tokens

cmdlet Get-AzureADUsers at command pipeline position 1
Supply values for the following parameters:
outfile: users.txt
[*] Gathering the users from the tenant.
---All Azure AD User Principal Names---

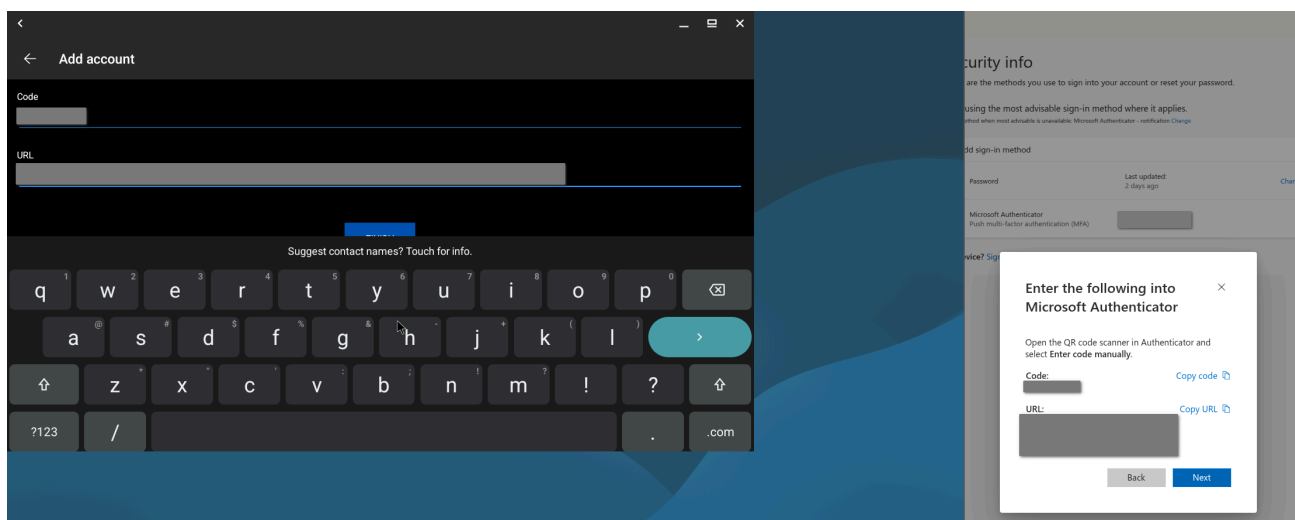
Discovered 4 users
```

However, this access is only temporary, and Red Team Engagements usually take place over a long period of time. Whenever we get initial access, we try to gather as much information as possible, while trying to remain stealthy and this takes time. So we try to establish persistence for the compromised account, so that we can get into it again if we need to. Our automated browser can be configured to automatically do this, by adding a new Authenticator app to the users account.

The way this works is just to navigate to the sign-in info page of the user's account, and add a new Authenticator app automatically:



We can then parse the Code and URL from the browser and add it to our own Authenticator app, which is running in an Android emulator:



Now, whenever we need to log in again, we can use the username, password and our own Authenticator app. However, this method also alerts the user, because a sign-in request

will pop up on their phone too. Therefore, we usually only use this as a last resort to regain access.

Lateral Movement

There are several ways of getting on-premise access from our cloud account:

SSO into VPN or Terminal Server

There are usually various services that are configured with Single-Sign-On. Once an account has been compromised, we can check app registrations to list services that are registered for SSO. If there are services like VPN portals or Remote-Desktop/Terminal-Servers, we can try to log in to them using our session. This is a quick way to get on-premise access.

Internal E-Mail Phishing

Another way to get on-premise access is to use the compromised account to send phishing e-mails to other employees. Since the e-mails are sent from a real account, the conversation history can be taken into account. For example, we can reply to an existing e-mail thread and add a malicious attachment or macro into an office file.

OneDrive / SharePoint File Compromise

We can also use the compromised account to search for shared files or folders in OneDrive or Sharepoint. If we find files that are shared with many users, we can modify them to include malicious payloads.

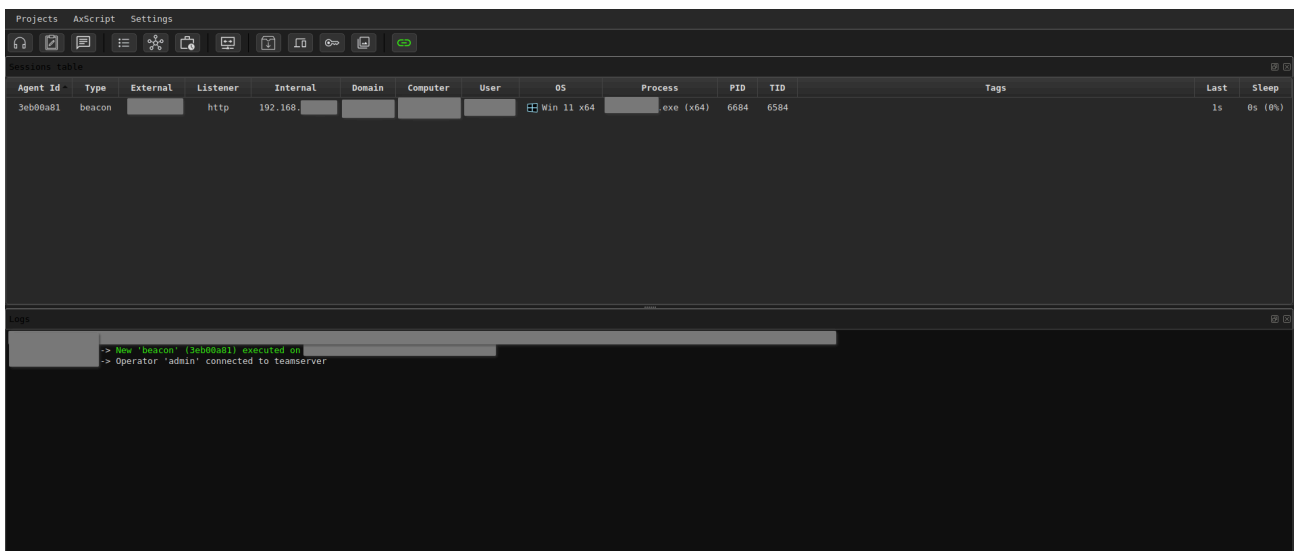
We need to keep in mind that these files still need to bypass Cloud-AVs and EDRs on the clients they will get synced to, but this method has several big advantages:

- Files are possibly synced to lots of clients
- The files are often executed without further inspection
- If we change existing files, they are likely to be allowlisted by AppLocker
 - This only works if the file is not allowlisted using its hash!
- There is no Mark-Of-The-Web on synced files

In this case, we simply added a shellcode-payload to an existing .exe file:

Documents

And after waiting for the file to sync, the payload eventually got executed:



Wrapping Up

We hope this second part gave some insight about what is possible after initial access is established and the first line of defense is breached. Using a flexible backend allows us to bypass common security measures and access policies.

Mitigation

- Implement Conditional Access policies, but do not rely on them as the only protection mechanism
- Hardening and testing cloud environments is as important as on-premise environments
 - Do not treat your hybrid environment as two separate entities!
- Configure access to SSO applications
 - Limit access to sensitive applications using Conditional Access
 - Protect those applications with additional MFA challenges

We will have a whole blog post about defense and mitigation in a third part!

Want to see our research and how your company reacts to real-world attacks in action?

[Contact us for a free initial consultation!](#)